

to the OTA Provider which provided the initial query response to indicate that the OTA Requestor has successfully applied the OTA Software Update Image. The OTA Requestor SHALL NOT retry at the application level to invoke this command if a response is not received.

In case the device performs a reboot in order to apply the update, the value of the [BootReason](#) attribute in the [General Diagnostics](#) cluster SHALL be set to [SoftwareUpdateCompleted](#).

NOTE

The above requirement was added in Matter 1.4.2. Devices certified before this version MAY return a different boot reason.

11.20.4. Security considerations

Security for the OTA Software Update capabilities encompasses these areas: Software Image verification, Software Image transport, and Software Image encryption. Security mechanisms in given applications dictate the security level of OTA upgrading. For example, an application with strict security policies (such as a smart lock) MAY support Software Image encryption at rest beyond the secure channel data-in-transit encryption, while other applications MAY only support data-in-transit encryption. Each Vendor SHALL decide the list of required security policies for their use of the OTA Software Update capabilities for a particular product.

11.20.4.1. Image Encryption

A Vendor MAY apply at-rest encryption to Software Image bodies, excluding the Software Update Image Header, using any algorithm of its choosing.

It is out of scope of this specification to mandate such means of protecting the confidentiality of the Software Images.

11.20.4.2. Image Verification

Asymmetric Verification of Authenticity and Integrity

The verification of the authenticity and integrity of Software Images by OTA Requestors is mandatory for security reasons. This is most often accomplished through asymmetric encryption technologies where only one entity is able to create a digital signature but many entities are able to verify it. Software Images SHALL be signed by a private key used by the Vendor for software image signing purposes, with that signature attached to the Software Image that is transported to the OTA Requestor. Once the complete Software Image has been received, the signature SHALL be verified using a matching public key known to the OTA Requestor performing the validation. See [Section 13.5, “Firmware”](#) for the associated security requirements. The format and algorithms used for code signatures verification are out of scope of this specification. The OTA Provider SHOULD NOT expect to be able to validate OTA Software Image signatures on its own.

OTA Requestors MAY be pre-installed with the certificate (public key) of the entity that created the signature, or they MAY receive the certificate over-the-air. How the signer's security data is obtained is considered outside the scope of the OTA Software Update Cluster and is Vendor Specific. When signer certificates are sent over-the-air, they SHALL be securely transferred from a trusted source to reduce the chance an attacker MAY inject their own signer certificate into the OTA Requestor.